情報処理安全確保支援士試験　科目A-2　中分類25 情報セキュリティ対策　#12

マルウェア対策・脆弱性管理・監視

見つける・備える・直す・見張る。運用の現場の対策

各ページの下に、根拠にした資料（IPA の支援士試験シラバス案、経済産業省、FIRST、CISA、NIST SP 800 など）を書いた。過去問は IPA 公開の午前 II 。例の場面は Claude が作った

全体像 シラバス案 中分類25 小分類5「情報資産運用に関する管理」

1 マルウェアとランサムウェア
パターンマッチング・ビヘイビア・ヒューリスティック、静的/動的解析、3-2-1・WORM・イミュータブル・カナリアファイル

2 脆弱性管理とデータ保護
CVSS・KEV・EPSS、パッチ管理、資産インベントリ、ASM/EASM、DLP、Web 分離、マスキング、削除

3 ログ管理と検知・監視
ログ設計・NTP・相関分析、シグネチャ/アノマリ、偽陽性/偽陰性、SIEM・EDR・NDR・XDR・SOAR

過去の午前 II での出方

テーマ	出た回
ビヘイビア法の説明	R3春
WAF のフォールスポジティブ	R5春・R6秋
インラインの IPS（シグネチャ／アノマリ）	R5春・R6秋
SOAR の説明	R6秋

ランサムウェア対策・ASM・XDR などはシラバス案で新しく例示された。科目B の事例でも出やすい。

出典：IPA「支援士試験 シラバス（案）Ver.0.1」中分類25 小分類5／IPA 午前 II 各回（このPDFの問題演習を参照）

第1章

マルウェアとランサムウェアへの対策

見つけ方と、やられても戻せる備え。

マルウェアの検出手法（R3春 問13）

手法	何を見るか	実行	未知
パターンマッチング法	定義ファイルの特徴的なコードと一致するか	**しない**	**×**
コンペア法	安全な場所の原本（ハッシュ値）と比べる	**しない**	**改変は分かる**
チェックサム法	事前に付けた「感染していない保証」と不整合か	**しない**	**改変は分かる**
ヒューリスティック法	コードの怪しい命令・構造を経験則で	**しない（静的）**	**○**
ビヘイビア法	読込み・書込み・通信などの**動作**を監視	**する**	**○**

静的解析：動かさずにハッシュ・文字列・逆アセンブル。難読化に弱い。

動的解析：サンドボックスで動かして観察。仮想環境を見抜いて黙るマルウェアに注意。

出典：IPA 午前 II 令和3年度春期 問13／IPA「支援士試験 シラバス（案）」用語例「ビヘイビア法，ヒューリスティック法，動的解析，静的解析」

ランサムウェアに負けないバックアップ

3-2-1 ルール

3	2	1
コピーを3つ（元データ含む）	2種類の媒体	1つは離れた場所

拡張の **3-2-1-1-0**：もう1つはオフラインか変更不可、復元テストでエラー0。

攻撃者は管理者権限を奪うと、**まずバックアップを消す**。同じ権限で届く場所は危ない。

対策	しくみ
バックアップ分離	ネットワーク・アカウントから切り離す
WORM	一度書いたら期間中は変更・削除不可（ワームではない）
イミュータブル	管理者でも消せないバックアップ
カナリアファイル	おとりファイルが触られたら警報
暗号化挙動検知	大量の書換え・エントロピー上昇・拡張子の一斉変更

出典：IPA「支援士試験 シラバス（案）」用語例〔ランサムウェア対策〕／NISC・警察庁・IPA ほか「ランサムウェア被害防止対策」／US-CERT「Data Backup Options」

第2章

脆弱性管理とデータ保護

知らない資産は守れない。直す順番を決める。

脆弱性の優先順位の付け方

指標	組織	分かること
CVE	MITRE	識別番号
CVSS	FIRST	深刻度 0.0〜10.0（v4.0 は 2023年）
EPSS	FIRST	30日以内に悪用される確率の予測
KEV	CISA	実際に悪用が確認された一覧
JVN	JPCERT/CC・IPA	国内製品を含む対策情報

判断の流れ

情報を集める
ベンダ・JVN・KEV

影響のある資産を特定
資産インベントリと照合

優先順位
深刻度×悪用状況×公開か×重要度

検証 → 段階適用 → 確認
当てられない機器は仮想パッチ・通信制限

CVSS 基本値は**深刻度**であり、自組織の**リスク**そのものではない。

出典：FIRST「CVSS v4.0 Specification」「EPSS」／CISA「KEV Catalog」／NIST SP 800-40 Rev.4 Guide to Enterprise Patch Management Planning

ASM：攻撃者の目で外から見る

① 発見
ドメイン・IP・公開サーバ・VPN 機器・クラウド

② 情報収集
ソフトの版数・開いているポート

③ リスク評価
既知の脆弱性・設定の不備

④ 継続的に繰り返す

EASM（External）＝インターネット側に絞った ASM。

見つかるのは、**管理部門が知らない資産**：海外子会社のサーバ、キャンペーン用に作って放置したサイト、廃止し忘れた VPN 装置。

経済産業省「ASM 導入ガイダンス」（2023年5月）が、手順と注意点（他人の資産を誤って調べない）をまとめた。

出典：経済産業省「ASM（Attack Surface Management）導入ガイダンス～外部から把握出来る情報を用いて自組織の IT 資産を発見し管理する～」2023年

データを守る：DLP・Web 分離・マスキング・削除

対策	しくみ	効く場面
DLP	データの**内容**（番号の形式・キーワード）を識別して持ち出しを止める	読む権限がある人の誤送信・持ち出し
Web 分離	隔離した環境のブラウザで閲覧し、端末には画面だけ送る	悪意のある Web での感染
データマスキング	伏せ字・置換。静的（テスト用の複製）と動的（表示時）	テスト環境・権限の低い閲覧者
情報の削除	SP 800-88 の Clear・Purge・Destroy	媒体の廃棄・再利用

アクセス制御は「**だれが読めるか**」。DLP は「読めた人が**外に出す**のを止める」。

SSD は上書きで消しきれない領域がある → **暗号消去**（鍵を消す）や Purge コマンド。

出典：IPA「支援士試験 シラバス（案）」用語例「DLP, Web 分離, 情報の削除及びデータマスキングの実装」／NIST SP 800-88 Rev.1 Guidelines for Media Sanitization

第3章

ログ管理と検知・監視

残す・そろえる・つなぐ・見張る。

ログ設計と相関分析

決めること	例
取得範囲	認証の成否、管理者の操作、通信の許可・拒否
保存期間	調査・法令・契約の要件から決める
改ざん防止	WORM・追記のみ・別サーバへ即転送
時刻同期	NTP で全機器を同じ時刻源に。タイムゾーンも統一

攻撃者は手元のログを消す → 別の場所へ送っておく。

相関分析の例（時刻がそろっていれば）

02:10 VPN：海外 IP から失敗×100

02:14 VPN：同じ ID で成功

02:20 認証サーバ：ファイルサーバへログオン

02:25 FW：外部へ 3GB 送信

単独では見逃す事象を、**一つの事案**としてつなげる。

出典：IPA「支援士試験 シラバス（案）」用語例〔ログの管理〕／NIST SP 800-92 Guide to Computer Security Log Management。例は Claude が作った

検知の方式 × 置き方（R5春 問12・R6秋 問13）

	シグネチャ型 異常を定義し合致で不正	アノマリ型 通常を定義し外れで不正
インライン 経路上に設置	R5春 正解	R6秋 正解
ミラーポート 経路外でキャプチャ	その通信は止められない	その通信は止められない

シグネチャ型＝誤検知少・未知に弱い。アノマリ型＝未知に強い・誤検知多。

WAF の判定（R5春 問10・R6秋 問12）

場面	分類
正当な数式の「<」を遮断	フォールスポジティブ
独自フィールドの攻撃を通す	フォールスネガティブ
分割したリクエストを通す	フォールスネガティブ
不正な文字列を遮断	正しい検知

出典：IPA 午前 II 令和5年度春期 問10・問12、令和6年度秋期 問12・問13

検知・対応の製品を見分ける

製品	見る範囲	役割
EPP	端末	入らせない（ウイルス対策）
EDR	端末	入られた後に検知・隔離
NDR	通信	横移動・C&C を通信から
XDR	端末＋通信＋メール＋クラウド＋ID	横断して検知・対応
SIEM	あらゆる機器のログ	集約・相関分析・警報
SOAR	各製品のアラート	プレイブックで対応を自動化

R6秋 問11 SOAR の説明はどれか

脅威インテリジェンス活用・運用の自動化・対応の効率化	SOAR
全てを信頼せず検証を自動化	ゼロトラスト
構造化した脅威情報の交換を自動化	TAXII
複数製品のログの集約・相関分析	SIEM

> SOC では**アラートトリアージ**と、誤検知の多いルールの調整でアラート疲れを防ぐ。

出典：IPA 午前 II 令和6年度秋期 問11／IPA「支援士試験 シラバス（案）」用語例〔検知・対応の基盤及び製品〕〔運用体制及び外部サービスの活用〕

まとめ：本番での問われ方

検出手法の当てっこ：動作を監視＝ビヘイビア、定義と一致＝パターンマッチング、原本と比較＝コンペア、事前の保証情報＝チェックサム。

2×2 の4択：インライン／ミラー × シグネチャ（異常を定義）／アノマリ（通常を定義）。

ランサムウェア：3-2-1、分離、WORM／イミュータブル。管理者権限でも消せないことが鍵。

偽陽性・偽陰性：正常を止めた＝フォールスポジティブ、攻撃を通した＝フォールスネガティブ。

脆弱性：深刻度（CVSS）に悪用状況（KEV・EPSS）と資産の状況を加える。ASM で知らない資産を見つける。

製品：SIEM＝集約と相関、SOAR＝自動対応、EDR＝端末、NDR＝通信、XDR＝横断。

出典：IPA 午前 II（このPDFの問題演習）／IPA「支援士試験 シラバス（案）Ver.0.1」